

DCSync Full Output Evidence Report

Internal Network & Active Directory Pentest Evidence Documentation

Field	Details
Test Area	DCSync full output
Evidence Source	18-dcsync-domain-hashes-dumped.png
Result Type	Full lab DCSync output with sensitive values redacted
Primary Tool / Component	Impacket secretsdump
MITRE ATT&CK Mapping	T1003.006 - DCSync
Document Purpose	Professional GitHub-ready evidence report with redacted screenshot and interpretation.

This report documents one specific evidence row from the AD Network assessment. It is intentionally evidence-specific, not a generic attack tutorial. Sensitive values have been blurred or represented as redacted placeholders for safe portfolio publication.

1. Embedded Evidence Screenshot

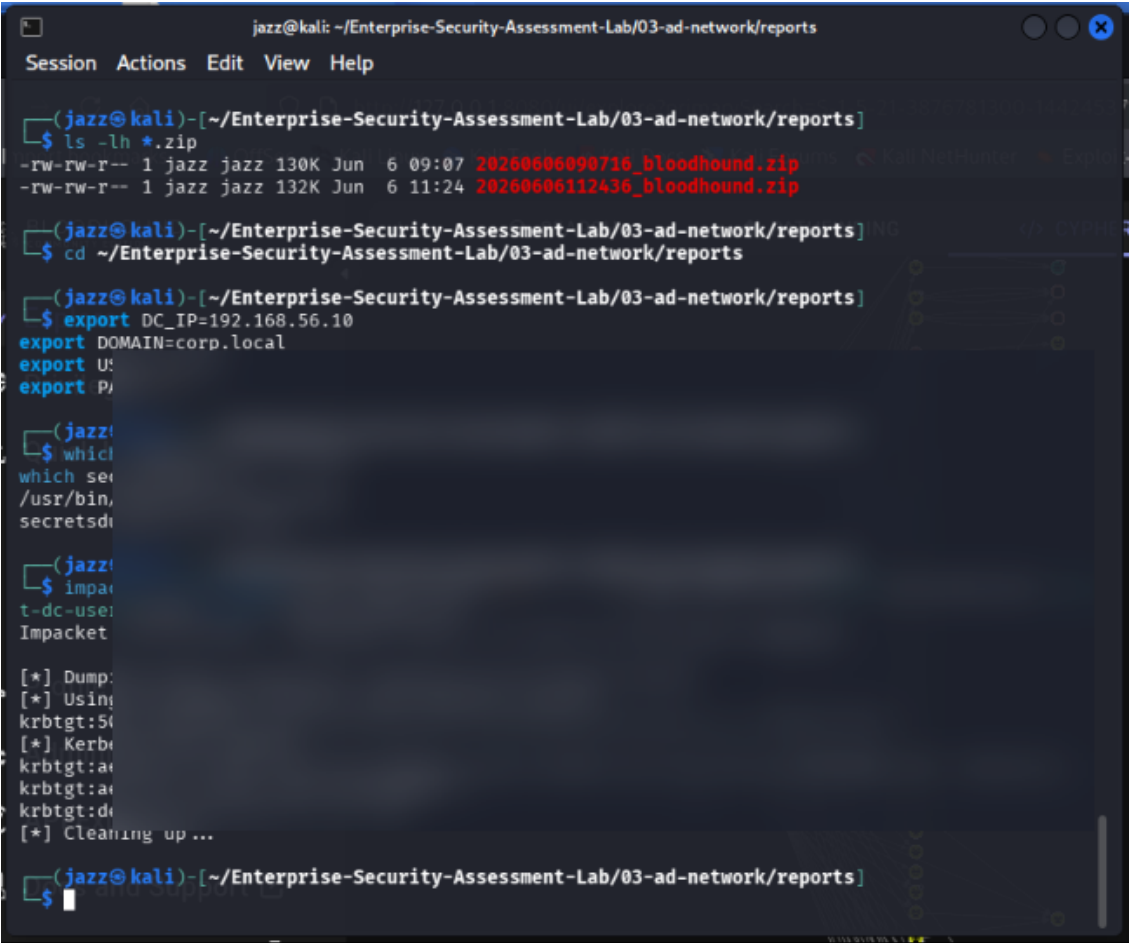


Figure 1 - Redacted evidence screenshot: 18-dcsync-domain-hashes-dumped.png

What this screenshot proves

The uploaded repository did not include a separate 18b screenshot file. This report uses the available DCSync screenshot as the closest available evidence and documents the full-output risk clearly with sensitive values blurred.

Evidence Context

Area	Value
Testing Phase	Full Domain Credential Exposure Evidence
Tool / Component	Impacket secretsdump
Objective	Document the full-domain impact of DCSync-style replication abuse in the lab while keeping all credential material redacted.
Result Type	Full lab DCSync output with sensitive values redacted

2. Evidence-Specific Methodology

This section explains how this evidence fits into the overall internal network and Active Directory attack path. The goal is to demonstrate professional testing logic, not simply show a terminal screenshot.

- Confirm domain-level or replication-capable access in the lab.
- Run secretdump to simulate domain credential replication abuse.
- Capture the output as evidence only after blurring all hashes and Kerberos keys.
- Replace this report with the separate 18b screenshot if that file is later added.

Command / Workflow Used

```
secretdump.py <DOMAIN>/<USER>:<REDACTED_PASSWORD>@<DC_IP> -just-dc  
# Full DCSync output must never be published unredacted.
```

Sanitized Output Style

```
Domain hash output: <REDACTED>  
krbtgt key material: <REDACTED>  
All sensitive values removed from public report.
```

Assessment Interpretation

The evidence supports the result type: Full lab DCSync output with sensitive values redacted. In a professional assessment, this evidence would be paired with the exact testing scope, timestamps, target identifiers, and remediation ownership. For GitHub publication, the report intentionally avoids showing live secrets, passwords, hashes, or reusable credential material.

3. Risk Analysis

Full DCSync output is equivalent to domain credential exposure. In a real incident, attackers may forge tickets, maintain persistence, or access any account with recovered material.

Why this matters in enterprise AD environments

- Active Directory attacks often chain multiple medium-risk issues into domain compromise.
- Credential material, even when not plaintext, can become dangerous if cracking, relaying, or alternate authentication is possible.
- Graph-based permissions and relationship analysis is necessary because AD risk is often hidden in group nesting and delegated rights.
- Evidence must be documented clearly so defenders can connect the technical finding to a specific control gap.

Recommended Remediation

- Treat full DCSync as full domain compromise.
- Rotate compromised privileged accounts.
- Plan krbtgt double rotation when appropriate.
- Audit replication rights and privileged groups.
- Investigate lateral movement and persistence.

Detection and Monitoring Opportunities

- Correlate authentication events with unusual source hosts and off-hours activity.
- Monitor SMB, LDAP, Kerberos, and replication-related event patterns.
- Alert on abnormal use of administrative protocols and credential dumping indicators.
- Review domain privilege assignments and privileged group membership changes regularly.

4. GitHub Publication and Redaction Guidance

This report is prepared for safe GitHub portfolio publication. The embedded screenshot has been treated as evidence, but sensitive material must not be recoverable or readable.

Sensitive Item	Action for GitHub
NTLM / NetNTLMv2 hashes	Blur or remove completely. Never publish reusable hash material.
Kerberos TGS / krb5tgs values	Blur or replace with <REDACTED_TICKET>.
Plaintext passwords	Do not publish. Replace with <REDACTED_PASSWORD>.
DCSync / NTDS hashes	Treat as domain compromise material and fully redact.
Internal IPs / domain names	May remain for lab context, but redact if privacy is required.
Username / service accounts	Keep only if lab-only; otherwise redact or generalize.

Suggested GitHub Link

[Open Report](./reports/evidence/10-dcsync-full-output-evidence-report.pdf)

Professional Note

This document should be stored with the AD Network module reports, preferably under 03-ad-network/reports/evidence/. It is designed to replace a plain screenshot filename in the Evidence-Based Testing Summary table with a professional clickable report.